OWASP TOP 10 INTERNET OF THINGS 2018

1 強度の弱いパスワード、推測可能なパスワード、もしくはパスワードのハードコード
総当たり攻撃で容易に解読される認証情報や、ありがちな認証情報を使うこと、あるいは認証情報が変更できないこと。ファームウェアやクライアントソフトウェアのバックドア機能には、デプロイされたシステムに対して本来許可されていないアクセスを提供するものもある。

2 安全でないネットワークサービス
デバイス上に不要な、もしくは安全ではないネットワークサービスが動作しており、特にインターネットに公開されているもの。これにより、情報の機密性、完全性／信頼性、可用性が侵害されたり、不正なリモート制御を許したりしてしまう。

3 安全でないエコシステムインタフェイス
デバイス外部のエコシステムに、デバイスや関連コンポーネントへの侵入を許してしまう安全でない Web、バックエンド API、クラウド、もしくはモバイルのインタフェイスがあること。認証／認可の欠如、暗号化の欠如もしくは脆弱な暗号化、入出力のフィルタリングの欠如がよくある問題として挙げられる。

4 安全な更新メカニズムの欠如
デバイスを安全に更新するための機能が欠如していること。デバイス上でのファームウェア検証、安全な配信（データ送信中に暗号化されていない）、ロールバック防止機構、更新によるセキュリティ変更の通知の欠如などがある。

5 安全でない、もしくは古いコンポーネントの使用
デバイスの侵害につながる非推奨、もしくは安全でないソフトウェアコンポーネント／ライブラリを使用していること。オペレーティングシステムのプラットフォームに対する安全でないカスタマイズや、侵害されたサプライチェーンからのサードパーティ製ソフトウェアやハードウェアコンポーネントの使用などもある。

6 不十分なプライバシー保護
利用者の個人情報がデバイス上やエコシステム内に保存されており、その利用者の個人情報が安全に使用されていない、不適切に使用されている、もしくは利用者の許可なく使用されていること。

7 安全でないデータの転送と保存
保存中、転送中、処理中といったエコシステム内のあらゆる場所での機微データの暗号化やアクセス制御が欠如していること。

8 デバイス管理の欠如
資産管理、更新管理、安全な廃棄、システム監視、レスポンス機能といった、本番環境にデプロイされたデバイスへのセキュリティ機能が不足していること。

9 安全でないデフォルト設定
デフォルトの設定が安全でない状態で出荷されたデバイスやシステムのこと。もしくは、使用者がシステムをより安全な状態にするための機能が制限されているデバイスやシステムのこと。

10 物理的なハードニングの欠如
物理的なハードニング対策がなされていないこと。そのため、潜在的な攻撃者が、リモート攻撃やデバイスのローカル制御を奪うために有益となる機微情報を入手できてしまうこと。

CC BY SA
原文：https://www.owasp.org/index.php/OWASP_Internet_of_Things_Project
翻訳：https://www.iac.co.jp/iacwatch/people/20190129_001755.html

■OWASP IoT Top10 とは

The Open Web Application Security Project(オワスプ)が発表している、IoT（Internet of Things：常時ネットワークに接続されデータを送受信する機器）でよく見られる脆弱性のTop10です。プロジェクトは2014年に開始され、Top10としては2018年12月に２度目の更新版が公開されました。開発者、製造業者、企業、および消費者がIoTシステムの作成と使用に関してより適切な決定を下すための手段としてご活用ください。

■OWASP KANSAIとは

Webセキュリティを取り巻く問題を解決する国際的なコミュニティOWASPの関西支部として2014年に設立されました。会社・立場・役割を超えて、それぞれができることでWebを確かなものにしていく仲間を増やす場です。OWASP KANSAIが開催するチャプターミーティングで情報交換を行い、お互いを高めあって行きましょう。



https://www.owasp.org/index.php/Kansai
#owaspkansai